Ghost STRIDE threat model: summary

Priority	Findings
High	3
Medium	11
Low	7
Total	**21**

STRIDE category (primary)	Findings
Spoofing	6
Tampering	5
Repudiation	1
Information disclosure	4
Denial of service	3
Elevation of privilege	2
Total	**21**

Elements with no distinct threat	1
Elements considered	39

TM-05 is counted under Spoofing (secondary: Repudiation).

Finding ID	Rank	Affected component / flow	STRIDE category
TM-01	1	P2 Post editor; P1 Admin browser application; DF3	Elevation of privilege
TM-02	2	P4 Admin API; DF3	Spoofing
TM-03	3	P7 Email delivery; DF12; DF13	Tampering
TM-04	4	P5 Public site and Content API; DF9	Tampering
TM-05	5	EE5 Publishing script; DF4; P4	Spoofing (also Repudiation)
TM-06	6	P5 Public site; P4 Admin API settings	Tampering
TM-07	7	P4 Admin API; DS1 integration keys	Tampering
TM-08	8	EE7 Recipient mailbox; DF14; DF9; P6	Spoofing
TM-09	8	EE1 Staff; EE2 Owner or Administrator; DF1; P1	Spoofing
TM-10	10	P6 Member authentication; P7; DF9; DF12; DF13; EE6	Denial of service
TM-11	11	EE6 Mailgun; DF15; P7; DF16; DS1	Spoofing
TM-12	12	P3 Nginx; P5; DF9	Denial of service
TM-13	13	DF6; DF10; DF16; DS1	Information disclosure
TM-14	14	DS4 Local logs; DF19; EE1; EE2	Repudiation
TM-15	15	P3 Nginx; DF5; DS4	Spoofing

TM-16	15	DS3 Config file; DF18; P8; P4; P7	Information disclosure
TM-17	17	DS2 S3 public bucket; DF17	Information disclosure
TM-18	17	P8 S3 adapter; DF7; DF8; DS2	Denial of service
TM-19	19	P9 Scheduler; DF11; DS1	Elevation of privilege
TM-20	19	P6 Member authentication; DF9	Information disclosure
TM-21	21	DS4 Logs; DF19	Tampering

Rank is shared where two findings were judged equally important. 'Compromised' means in-sco

Threat mechanism and consequence
A staff user stores active script in a raw HTML card. When an Admin or Owner opens, edits or previews the post, the script runs in their authenticated browser and issues Admin API calls as them. A Contributor, Author or Editor thereby acts with Admin or Owner authority (settings, integrations, code injection).
A stolen staff session cookie is replayed. Password and new-device verification apply only at login, and verification at every login is not configured, so the holder acts as the staff user until the session ends.
A compromised Author or Editor publishes a post with deceptive content or links that is sent as a newsletter to all free members. It comes from the publication's trusted sender via Mailgun, enabling mass phishing and damaging sender reputation.
Script embedded in a published post through a raw HTML card runs in readers' and members' browsers. It can alter page content, redirect users, or perform actions riding a member's session.
A stolen integration key lets an attacker sign valid JWTs and create or publish posts as the integration. Actions are attributable only to the integration, so the legitimate script operator cannot be distinguished from the thief.
A malicious Admin or Owner (or a stolen admin session) uses code injection to place script on every public and member page. This affects all visitors at once and persists until removed.
A compromised Admin session creates a new integration key. That key is not tied to the session or to device verification, so access survives session revocation and password reset.
An attacker who controls a recipient mailbox reads a staff verification code or redeems a member login link. With a known staff password, the code defeats new-device verification. Member impersonation yields member-level access only.
A lookalike admin login page harvests credentials and relays the emailed verification code in real time, defeating new-device verification.
Mass login or signup requests for arbitrary addresses flood victims and exhaust Mailgun quota or rate limits. Because staff verification mail uses the same channel, new-device staff logins and member logins can be delayed or blocked.
Forged delivery or engagement callbacks hit the HTTPS endpoint. They can mark members as bounced or complained, suppress newsletters, or distort delivery records stored in DS1.
A high-volume request flood saturates the single Node.js server or Nginx. No WAF is configured, so the public site and Admin API become unavailable.
Database traffic is not assumed to use TLS, so an attacker on the private path can read password hashes, session records, integration keys, member emails and content. Session records could enable hijack.
Audit evidence is local only, with no archive or monitoring. After a compromise or insider action, staff, admins or integrations can deny actions that cannot be reconstructed, and the activity may go undetected.
Ghost sees only loopback traffic and may rely on a forwarded client-IP header. A forged header could evade login or request throttling and falsify logged source addresses.

Logical processes share server privileges. A file-read or code-execution flaw in a component that handles untrusted input would expose database, Mailgun and S3 credentials.
Draft images are publicly readable without Ghost authorization. Anyone who learns the URL can view unpublished or embargoed imagery.
A compromised staff account bulk-uploads large or numerous images, exhausting bucket storage or cost, or errors the adapter for legitimate uploads.
A user schedules posts and is then demoted or removed. If authority is not re-checked at publish time, their content still goes live.
Login or signup responses may differ for registered and unregistered emails, letting an anonymous attacker enumerate which addresses are members.
Attacker-controlled strings (email, user agent, URL) written to line-based logs could forge or obscure entries.

pe account compromise as an initial condition. Source: system package and diagram

Required initial attacker access	Additional assumption	Priority
Compromised Contributor, Author or Editor	Raw HTML cards are insertable by all staff roles, including Contributors in drafts. Editor or preview renders card content as executable script in the admin origin. A higher-privileged user opens the post.	High
Holder of a stolen staff session	None	High
Compromised Author or Editor	Publishing can trigger a newsletter send without a second approval. Raw HTML or links survive into the email body.	High
Compromised Author or Editor (Contributor drafts reach the public only if an Editor publishes them)	None beyond the stated raw HTML setting	Medium
Holder of the stolen integration key	None	Medium
Compromised or malicious Owner or Administrator	Injected code is rendered on member-facing pages in the same origin as the member session.	Medium
Compromised Owner or Administrator (session)	Admins can create integrations with publishing permission, and keys remain valid until deleted.	Medium
Access to a staff or member mailbox (plus the staff password for the staff case)	None	Medium
Anonymous Internet attacker	Staff are lured to the attacker's page and enter the code.	Medium
Anonymous Internet attacker	Member link requests are not throttled per recipient or globally. Transactional and newsletter sending share one Mailgun quota or reputation.	Medium
Anonymous Internet attacker	Callbacks are not authenticated, since the package forbids crediting signature validation.	Medium
Anonymous Internet attacker	Attacker traffic can exceed single-VM capacity.	Medium
Network position on the private VM-to-MySQL path	The attacker has that position, which is not a listed in-scope attacker class.	Medium
Any staff account, malicious or compromised	Ghost keeps no per-action audit trail beyond DS4, and logs are rotated or lost with the VM.	Medium
Anonymous Internet attacker	Throttling and logs use a header that P3 does not overwrite.	Low

Application-level foothold through an in-scope entry point (staff upload or public request)	A defect exists in a component that handles untrusted input (for example, image handling).	Low
Anonymous reader who knows or guesses the object URL	URLs are predictable or leak through shared links, referrers or previews. Listing is disabled per the package.	Low
Compromised staff with upload ability	No upload size, count or quota limits beyond validation.	Low
Compromised or malicious Author or Editor	P9 does not re-evaluate the role at publication time.	Low
Anonymous Internet attacker	Responses reveal membership status.	Low
Anonymous Internet attacker or malicious member	Inputs are logged without sanitization.	Low

sheets (Revision 1.0).

Priority justification
Crosses TB6 from a low role to full control. The package states that HTML is not guaranteed free of active behavior, and origin protections do not stop same-origin script.
Bypasses every login control. Impact is full Admin control if the victim is an Admin or Owner.
Reaches every member through a trusted channel, and the sent mail cannot be recalled.
Reach is wide, but impact is bounded to client-side effects on public and member pages.
The key is limited to the publishing permission set, not Owner authority, but published raw HTML amplifies the effect.
Reach is site-wide, but it uses a legitimate privilege and admin compromise is already assumed.
Gives durable access, but only at integration-level authority.
TB7 makes mail possession authentication-relevant, but the attacker needs a prior mailbox compromise.
Needs user interaction, but a success yields a full staff session.
Cascading effect on authentication, with no credentials needed.
Needs no credentials, but impact is limited to email delivery state.
Easy to attempt, and there is one server and no mitigation layer, but it is generic and transient.
High impact, but it needs a precondition outside the stated attacker set.
Weakens detection and accountability for every other finding.
New-device verification still gates staff logins, so the impact is limited to weaker throttling and noisier logs.

Impact would be high, but the premise requires an assumed defect.
Limited to image content, and the URL must be obtained first.
Affects availability of uploads and cost, not content.
The same user could have published earlier.
Limited privacy leak.
Only degrades evidence quality.

Element ID	Type	Name / endpoints
EE1	External entity	Staff user including Contributor Author Editor
EE2	External entity	Owner or Administrator
EE3	External entity	Free member
EE4	External entity	Anonymous reader
EE5	External entity	Server side publishing script
EE6	External entity	Mailgun email provider
EE7	External entity	Recipient mailbox service
P1	Process	Admin browser application
P2	Process	Post editor including session save engine and publish UI
P3	Process	Nginx reverse proxy
P4	Process	Admin API
P5	Process	Public site and Content API
P6	Process	Member authentication
P7	Process	Email delivery and provider event handling
P8	Process	S3 image storage adapter
P9	Process	Publication scheduler
DS1	Data store	MySQL core data
DS2	Data store	S3 public image bucket
DS3	Data store	Server configuration file
DS4	Data store	Local application and proxy logs
DF1	Data flow	EE1,EE2 to P1
DF2	Data flow	P1 to P2
DF3	Data flow	P1,P2 to P3
DF4	Data flow	EE5 to P3
DF5	Data flow	P3 to P4,P5,P6,P7
DF6	Data flow	P4 to DS1
DF7	Data flow	P4 to P8
DF8	Data flow	P8 to DS2
DF9	Data flow	EE3,EE4 to P3
DF10	Data flow	P5,P6 to DS1
DF11	Data flow	P4 to P9
DF12	Data flow	P9,P6,P4 to P7
DF13	Data flow	P7 to EE6
DF14	Data flow	EE6 to EE7
DF15	Data flow	EE6 to P3
DF16	Data flow	P7 to DS1
DF17	Data flow	EE3,EE4 to DS2
DF18	Data flow	DS3 to P4,P7,P8
DF19	Data flow	P3,P4,P6,P7 to DS4

Coverage checklist is not part of the finding count. Data flow names show endpoints from the package's flo

Associated finding IDs	Finding count
TM-01, TM-02, TM-03, TM-04, TM-09, TM-14, TM-18, TM-19	8
TM-02, TM-06, TM-07, TM-09, TM-14	5
TM-03, TM-04, TM-06, TM-08, TM-10, TM-11, TM-20	7
TM-10, TM-11, TM-12, TM-15, TM-17, TM-20, TM-21	7
TM-05	1
TM-10, TM-11	2
TM-08	1
TM-01, TM-09	2
TM-01	1
TM-12, TM-15	2
TM-02, TM-05, TM-06, TM-07, TM-16	5
TM-04, TM-06, TM-12	3
TM-08, TM-10, TM-20	3
TM-03, TM-10, TM-11, TM-16	4
TM-16, TM-18	2
TM-19	1
TM-07, TM-11, TM-13	3
TM-17, TM-18	2
TM-16	1
TM-14, TM-21	2
TM-09	1
No distinct threat identified	0
TM-01, TM-02	2
TM-05	1
TM-15	1
TM-13	1
TM-18	1
TM-18	1
TM-08, TM-10, TM-12, TM-20	4
TM-13	1
TM-19	1
TM-03, TM-10	2
TM-03, TM-10	2
TM-08	1
TM-11	1
TM-11, TM-13	2
TM-17	1
TM-16	1
TM-14, TM-21	2

w ledger.